a's'd

AI 协作检查清单

核心原则：AI 负责产出草稿，你负责判断与把关 —— 责任永远在你这边。

① 提需求前：想清楚再开口

- [ ] 目标：一句话说清要做什么
- [ ] 输入 / 输出：数据从哪来、长什么样、要返回什么
- [ ] 约束：框架/库版本、性能、禁用依赖
- [ ] 边界：空值、超大输入、并发、出错怎么办
- [ ] 上下文：贴相关代码/模型/报错，别让它猜

② 拿到代码：先读后跑

- [ ] 我能逐行解释它在做什么吗？
- [ ] 用到的库/函数/参数真实存在吗？
- [ ] 依赖是否最小、无过度设计？
- [ ] 错误处理在哪？异常会被悄悄吞掉吗？
- [ ] 边界条件处理了吗？
- [ ] 有没有把密钥/密码写死在代码里？

③ 安全红线（后端尤其盯）

- [ ] SQL/命令注入：有没有字符串拼接？必须参数化
- [ ] 越权：校验“这条数据是不是他的”，而非只“登录了没”
- [ ] 密码：用 bcrypt/argon2，不明文、不 md5
- [ ] 输入校验：外部输入先过 schema 再用
- [ ] 密钥：从环境变量读，不硬编码进仓库

④ 绝不全权交给 AI

- [ ] 生产数据库的删除 / 迁移
- [ ] 密钥、凭据、权限边界设计
- [ ] 涉及钱、隐私、对外发布的最终决策

以上 AI 可给建议，但必须由你审查后手动把关。

⑤ 调试协作

- [ ] 给 AI：完整报错 + 栈追踪 + 相关代码 + 你试过什么
- [ ] 先问“为什么会错”，别盲目复制“换个写法”

⑥ 作业里的协作记录

- [ ] 我让 AI 做了什么（关键提示）
- [ ] 我改了/否决了哪些地方，为什么
- [ ] 我做了哪些验证（跑了什么、测了什么边界）

考核的是你的判断力，不是代码出自谁。坦诚写不扣分，隐瞒才会。